

Chapter 3 — Privileged Access, Break-Glass, Credentials, and Service Identities

1. Document control

- Identifier: HAL-BVI-03
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Control privileged and emergency access, credential issuance and lifecycle, non-human identity, and recovery from privileged compromise.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 27, 38-40, 48
- Book II: Chapters 3-5, 23, 28, 33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-01-03, CMP-25-26
- Book X: Chapters 3-4, 8-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Privileged Access Owner, Incident Commander, Credential Custodian, Service Owner, Security Operations, Independent Reviewer.

6. Normative controls

VI-PAM-03-001 — Broker privileged access

Privileged access MUST use an approved broker or equivalent controlled path with strong authentication, current Authority and Permission, session bounds, command or action evidence, and automatic expiry.

- Applicability: privileged access
- Responsible role: Privileged Access Owner
- Enforcement: privileged access gateway
- Required evidence: session evidence
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PAM-03-002 — Use just-in-time elevation

Standing privilege SHOULD NOT exist; elevation MUST be just-in-time, purpose-specific, time-limited, approved at the appropriate risk level, and removed automatically.

- Applicability: privileged roles
- Responsible role: Privileged Access Owner
- Enforcement: elevation workflow
- Required evidence: elevation record
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-PAM-03-003 — Constrain break-glass

Break-glass access MUST require a declared emergency, narrow scope, an independent Permission decision bounded by current Authority where reachable, enhanced monitoring, immutable evidence, automatic expiry, and retrospective review within 24 hours.

- Applicability: emergencies
- Responsible role: Incident Commander
- Enforcement: emergency access workflow
- Required evidence: break-glass record and review
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-PAM-03-004 — Protect Owner ceremonies

Credentials or privileged access MUST NOT substitute for the Owner Authorization Ceremony or other constitutionally protected approval.

- Applicability: protected Owner actions
- Responsible role: Privileged Access Owner
- Enforcement: Kernel ceremony-admission test
- Required evidence: ceremony evidence reference
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-PAM-03-005 — Issue workload-bound service identities

Each service identity MUST bind to an approved workload, environment, owner, capability need, permitted audience, credential method, and rotation/revocation policy.

- Applicability: service identities
- Responsible role: Service Owner
- Enforcement: workload identity admission
- Required evidence: service identity record
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Protect HAL

VI-PAM-03-006 — Eliminate embedded credentials

Credentials **MUST NOT** be stored in source, images, logs, tickets, prompts, generated artifacts, or unapproved configuration; discovery **MUST** trigger containment and rotation.

- Applicability: all artifacts
- Responsible role: Credential Custodian
- Enforcement: secret scanning and admission gates
- Required evidence: scan results and rotation record
- Severity: Critical
- Exception authority: None
- Protection objective: Protect HAL

VI-PAM-03-007 — Rotate on defined triggers

Credentials **MUST** rotate on scheduled lifetime, exposure, custody change, algorithm or issuer weakness, workload change, environment migration, and incident direction.

- Applicability: all credentials
- Responsible role: Credential Custodian
- Enforcement: lifecycle controller
- Required evidence: rotation and revocation receipts
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Protect HAL

VI-PAM-03-008 — Investigate privileged anomalies

Unexpected privilege use, failed elevation, geographic or workload mismatch, bulk access, disabled telemetry, or policy bypass attempt **MUST** create an incident-relevant event and risk-based response.

- Applicability: privileged activity
- Responsible role: Security Operations
- Enforcement: behavior detection
- Required evidence: security event and disposition
- Severity: Critical
- Exception authority: None
- Protection objective: Both

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence MUST identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 27, 38-40, 48
- Book II: Chapters 3-5, 23, 28, 33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-01-03, CMP-25-26
- Book X: Chapters 3-4, 8-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a credential with favorable Trust evidence, passing scan, active certificate, or urgent incident as Permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.